PARTE 2 — Perícia de Rede no Wireshark

QUESTÃO 1 — Reconhecimento do dispositivo Localize a telemetria publicada pelo dispositivo da câmara (tópico MQTT que termina em /telemetria) e complete o quadro:

Campo	Resposta
IP do dispositivo (cliente) / versão do IP	192.168.20.31
IP do servidor/broker / versão do IP	192.168.20.10
Protocolo de aplicação usado na telemetria	mqtt
Porta de destino (broker)	1883
Modelo da placa informado no JSON (campo "placa")	ESP32
Tópico MQTT da telemetria	biofrio/cam03/telemetria

QUESTÃO 2 — Credenciais em texto claro O painel web da BioFrio ainda opera sobre HTTP, sem TLS. Responda:

a) Qual o usuário enviado no formulário de login do painel?

tecnico.cam03

b) Qual a senha enviada? Atenção à codificação de URL — explique o que significa `%40`.

A senha capturada foi:

Vac%40BioFrio2026

O código %40 é a codificação URL do caractere @. Portanto, a senha real é:

Vac@BioFrio2026

c) Qual identificador de sessão (cookie) o servidor devolveu após o login?

O servidor enviou o cookie: **session=c6a1f09b7d2e4418**

Portanto, o identificador de sessão é: **c6a1f09b7d2e4418**

d) O broker MQTT também recebeu usuário e senha em texto claro. Informe o usuário e a senha usados pelo dispositivo para se conectar ao broker.

No pacote MQTT de conexão aparecem:
Usuário: vaxguard **Senha:** Fr10#Cam03

e) Que falha de segurança essas observações evidenciam? Que correções você recomendaria?
Eu recomendaria Utilizar **HTTPS/TLS** no painel web.
Utilizar **MQTT sobre TLS (MQTTS)**, normalmente na porta 8883.
Não transmitir ou armazenar credenciais de forma exposta.
Utilizar **autenticação forte** e controle de acesso para os clientes MQTT.
Proteger os cookies de sessão com opções como **Secure** e **HttpOnly**.

QUESTÃO 3 — Comando suspeito no broker Por volta das 14:14:30, aparece uma publicação MQTT no tópico de comandos (biofrio/cam03/cmd). Analise-a e responda:

a) Qual host publicou esse comando e qual era o comando (conteúdo da mensagem)?

O comando foi publicado pelo host: **192.168.20.66**

No tópico: **`biofrio/cam03/cmd`**

O conteúdo da mensagem foi: **`{"cmd":"VENTILACAO_OFF","cmd_id":"x90"}`**

b) Esse host é o servidor autorizado (192.168.20.10)? Justifique comparando o IP de origem dessa publicação com o IP de onde vêm as respostas legítimas do sistema.

O servidor autorizado é: **192.168.20.10**
O comando suspeito veio de:**192.168.20.66**
Isso indica que um host diferente do servidor autorizado conseguiu publicar no tópico de comandos. Além disso, as respostas legítimas do

sistema partem do broker **192.168.20.10**, enquanto a publicação original do comando veio de **192.168.20.66**.

c) O dispositivo estava inscrito nesse tópico (procure o pacote Subscribe)? Explique, então, por que o broker repassou o comando ao dispositivo logo em seguida.
Sim, o dispositivo **192.168.20.31** realizou um **Subscribe** para o tópico: **biofrio/cam03/cmd**
Como ele estava inscrito nesse tópico, quando o host **192.168.20.66** publicou a mensagem, o broker **192.168.20.10** repassou o comando ao dispositivo. O problema é que o broker aparentemente **não restringia adequadamente quem poderia publicar nesse tópico**.

d) Relacione esse comando com a excursão térmica: observe os valores de temp e estado na telemetria antes e depois das 14:14:30 e descreva o efeito provável do comando.
Antes do comando, a temperatura estava aumentando:
17:13:05 → 8,6 °C — ATENÇÃO
17:13:35 → 9,2 °C — ATENÇÃO
Às **17:14:30**, o host não autorizado publicou:
VENTILACAO_OFF
Depois disso, a temperatura continuou aumentando:

- **17:15:05 → 10,4 °C — CRÍTICO**
- **17:15:35 → 11,9 °C — CRÍTICO**
- **17:16:05 → 13,5 °C — CRÍTICO**

Assim, o comando provavelmente **desligou a ventilação/refrigeração**, contribuindo para a elevação da temperatura e para a condição **CRÍTICA** registrada posteriormente.

e) Que mecanismo de segurança (ausente aqui) teria impedido que um host qualquer publicasse um comando aceito pelo dispositivo? Cite ao menos dois.
Pelo menos dois:

1. **Controle de acesso/ACL no broker MQTT**, permitindo que somente o servidor autorizado publique em biofrio/cam03/cmd.

2. **Autenticação forte dos clientes MQTT**, com credenciais individuais e permissões específicas.
   Também seria recomendável:

- **TLS/MQTTS** para proteger a comunicação.
- **Assinatura ou autenticação das mensagens**, para garantir que o comando realmente veio de uma origem autorizada.
- Separação de permissões entre **publicação e assinatura**.

QUESTÃO 4 — Linha do tempo e recomendações

a) Monte uma linha do tempo do incidente (horário → evento), do primeiro login à última leitura CRÍTICA.

Horário	Evento
17:10:00	Dispositivo acessa o painel web e envia login com usuário tecnico.cam03 e senha codificada na URL.
17:10:00	Servidor responde ao login e devolve o cookie de sessão c6a1f09b7d2e4418.
17:10:01	Dispositivo inicia conexão MQTT com o broker 192.168.20.10:1883.
17:10:01	Dispositivo se autentica no MQTT usando vaxguard e Fr10#Cam03.
17:10:01	Dispositivo faz Subscribe em biofrio/cam03/cmd.
17:10:05	Primeira telemetria: **4,8 °C — NORMAL**.
17:10:35–17:12:35	Temperatura aumenta gradualmente de **5,0 °C para 7,8 °C**.
17:13:05	Temperatura chega a **8,6 °C — ATENÇÃO**.
17:13:35	Temperatura chega a **9,2 °C — ATENÇÃO**.
17:14:30	Host **192.168.20.66** publica o comando suspeito VENTILACAO_OFF.
17:14:30	Broker 192.168.20.10 repassa o comando ao dispositivo 192.168.20.31.

Horário	Evento
17:15:05	Temperatura chega a **10,4 °C — CRÍTICO**.
17:15:35	Temperatura chega a **11,9 °C — CRÍTICO**.
17:16:05	Última leitura: **13,5 °C — CRÍTICO**.

b) Classifique o incidente: foi uma falha do equipamento, um erro de operação ou uma ação maliciosa? Fundamente com os pacotes observados.

O incidente pode ser classificado como uma **ação maliciosa**. A principal evidência é que o comando: `VENTILACAO_OFF` foi publicado pelo host **192.168.20.66**, que é diferente do servidor autorizado **192.168.20.10**.

O broker, mesmo assim, aceitou a publicação e repassou o comando ao dispositivo. Depois disso, a temperatura continuou subindo, passando de **9,2 °C — ATENÇÃO** para **13,5 °C — CRÍTICO**. Portanto, os pacotes indicam uma **ação não autorizada que provavelmente contribuiu para a excursão térmica**.

c) Proponha três medidas técnicas que a BioFrio deveria adotar para que esse mesmo tráfego, se capturado de novo, não revelasse credenciais nem permitisse comandos não autorizados (pense em criptografia de transporte, autenticação de mensagens e controle de acesso ao broker).

Implementar **HTTPS** no painel e **MQTT sobre TLS/MQTTS** para impedir que usuários, senhas, cookies e mensagens sejam facilmente obtidos por alguém capturando o tráfego.

2. Autenticação e integridade das mensagens Utilizar autenticação forte e mecanismos como **assinatura/autenticação de mensagens**, garantindo que comandos recebidos pelo dispositivo tenham vindo de uma origem autorizada e não tenham sido alterados.

3. Controle de acesso no broker MQTT Configurar **ACLs** no broker para determinar exatamente quem pode publicar e assinar cada tópico. Por exemplo, somente o servidor autorizado **192.168.20.10** deveria poder publicar comandos em:

d) `biofrio/cam03/cmd`

e) Dessa forma, mesmo que outro computador da rede tente publicar nesse tópico, o broker deverá **recusar a mensagem**.